# Checklist LGPD e auditoria de logs (T-25)

Perfila · Equipe Omega · 11/11/2026 · Spec v1.2

Interpretação técnica da equipe sobre a Lei 13.709/2018, **não é parecer jurídico** (CLAUDE.md, seção 4). Cada item aponta a evidência que o prova: um cenário BDD, um teste automático ou um arquivo de configuração. ✅ atendido no MVP · ⚠️ atendido com limitação · ⬜ fora do MVP (requisito futuro).

## 1. Consentimento (UC-08, UML5)

| # | Requisito | Como o Perfila atende | Evidência | |
|---|---|---|---|---|
| L-01 | Nenhum dado pessoal é processado sem consentimento válido | `Precondicoes.Verificar` em UC-01 a UC-04 e, em reforço, middleware LGPD na API (C-03, RN-01) | cenários `@lgpd` em `evento`, `perfilamento`, `segmentacao`, `recomendacao` e `api.feature`; `TestFluxoPontaAPonta` (403 antes do consentimento) | ✅ |
| L-02 | Consentimento é livre e explícito: ausência de registro não vale como consentimento | Sem registro equivale a NAO_CONCEDIDO (D-02); cadastro (UC-09) não concede nada | `consentimento.feature` ("sem registro"), `cliente.feature` | ✅ |
| L-03 | Revogação a qualquer momento, com efeito imediato | `Revogar` muda o estado; UC-01 a UC-04 passam a falhar na hora (RN-03) | `consentimento.feature`, `api.feature`; `TestFluxoPontaAPonta` (403 após revogar) | ✅ |
| L-04 | Finalidade e versão do termo registradas | `Finalidade` e `VersaoTermo` obrigatórias em `Conceder` (guarda da 3.4.1) | `consentimento.feature` (guarda violada) | ⚠️ a finalidade é registrada, mas não filtra o uso dos dados (RN-02) |
| L-05 | Prova de quando o titular consentiu e revogou | `DataConsentimento`, `DataRevogacao` (mantida após nova concessão, Q-01) e `DataAtualizacao` em UTC | `consentimento.feature`; contrato `Consentimento` nos dois backends | ✅ |
| L-06 | Troca de termo deixa histórico explícito | Conceder sobre CONCEDIDO é `transicao_invalida`; é preciso revogar e conceder de novo (Q-06) | `consentimento.feature`, `api.feature` (409) | ⚠️ guarda só o último registro, não o histórico completo de versões |

## 2. Minimização e qualidade dos dados

| # | Requisito | Como o Perfila atende | Evidência | |
|---|---|---|---|---|
| L-07 | Coletar só o necessário | Dado pessoal direto: só nome e e-mail do cliente. Eventos, perfil, segmento e recomendação usam apenas o `ClienteID` (UUID aleatório) | Spec 3.2; `001_inicial.sql` | ✅ |
| L-08 | Dados de teste e demonstração sintéticos | IDs `c-001`, e-mails `@exemplo.test`, catálogo inventado (B-08) | varredura do repositório sem e-mails reais (11/11); `seed.go`, `002_dados_demonstracao.sql` | ✅ |

| # | Requisito | Como o Perfila atende | Evidência | |
|---|---|---|---|---|
| L-09 | Perfilamento explicável | Regras determinísticas e testáveis: RN-05 (perfil), RN-06 (critério declarativo), RN-07 (recomendação); o motivo vai na resposta ( `segmento:<nome>;categoria:<categoria>` ) | `perfilamento.feature` , `segmentacao.feature` , `recomendacao.feature` | ✅ |

## 3. Segurança (art. 46)

| # | Requisito | Como o Perfila atende | Evidência | |
|---|---|---|---|---|
| L-10 | Tráfego do titular cifrado | Nginx com TLS 1.2/1.3 e HSTS; a única porta publicada é a HTTPS (Q-12) | `deploy/nginx/nginx.conf` ; cenário "todo o tráfego entra pelo balanceador" (confere TLS) | ⚠️ certificado autoassinado na demonstração; em produção, montar um certificado real |
| L-11 | Banco inacessível de fora | `db` só na rede interna `dados` , sem porta publicada | `deploy/docker-compose.yml` ; cenário "o banco não é acessível pelo dispositivo do cliente" | ✅ |
| L-12 | Acesso à API autenticado | Bearer `AUTH_TOKEN` comparado em tempo constante; 401 sem token (D-16) | `api.feature` (401) | ⚠️ token estático único; JWT e perfis de acesso fora do MVP |
| L-13 | Segredos fora do código | Senha do banco e `AUTH_TOKEN` gerados aleatoriamente em `deploy/.env` e `deploy/config.env` , ignorados pelo git (Q-14); a URL do banco nunca vai para log ou erro | `scripts/preparar-implantacao.sh` ; `.gitignore` ; `TestArgumentosEConfig` (senha ausente do erro) | ✅ |
| L-14 | Menor privilégio | `omega-server` roda como usuário sem privilégio (uid 10001), binário estático | `deploy/Dockerfile` | ✅ |
| L-15 | Integridade dos dados | Chaves estrangeiras, `UNIQUE(cliente_id)` e `CHECK` nos estados e faixas (Spec 3.8) | `001_inicial.sql` ; suíte de contrato | ✅ |
| L-16 | Cifra em repouso e entre balanceador e réplicas | — | — | ⬜ volume do PostgreSQL e tráfego interno Nginx → réplicas sem cifra (rede Docker isolada) |

## 4. Direitos do titular (art. 18)

| # | Direito | Situação | |
|---|---|---|---|
| L-17 | Confirmação e consulta do consentimento | `GET /v1/clientes/{id}/consentimento` | ✅ |
| L-18 | Revogação | `POST /v1/clientes/{id}/consentimento/revogacao` | ✅ |
| L-19 | Acesso, correção, portabilidade e eliminação dos dados | `Cliente.AtualizarDados` existe no domínio, mas não há rota; não há exportação nem eliminação | ⬜ |
| L-20 | Retenção e eliminação após revogação | Dados já persistidos permanecem (RN-03); política fora do MVP (D-13) | ⬜ |

## 5. Auditoria de logs (C-09)

Todos os eventos de log do sistema, conferidos no código em 11/11/2026 ( `grep` por chamadas de `slog` em `cmd/` e `internal/` ):

| Evento | Origem | Campos | Dado pessoal? |
|---|---|---|---|
| `http` | `api.Registro` | método, caminho (só UUIDs), status, duração | Não. A query string não é registrada |
| `erro_interno` | `api.escreverErro` (só erros 500) | caminho, mensagem do erro | Não. Os erros de infraestrutura citam só IDs; os do driver trazem a mensagem do PostgreSQL, sem os valores |
| `recomendacao_ativada` | UC-04 (notificação reduzida a log, D-08) | IDs da recomendação, do cliente e do produto | Não |
| `servidor_no_ar` , `encerrando` , `modo_memoria` | `cmd/omega-server` | porta, aviso fixo | Não |
| `postgres_conectado` | `cmd/omega-server` | versões de migração aplicadas | Não. A URL do banco não é registrada |
| `recomendacoes_expiradas` | subcomando `expirar-recomendacoes` | quantidade | Não |
| acesso do Nginx | `deploy/nginx/nginx.conf` ( `log_format omega` ) | horário, método, caminho sem query string, status, tempo, réplica, id da requisição | Não. **Sem IP do cliente** (IP é dado pessoal, Q-14) |
| PostgreSQL | configuração padrão da imagem | erros, sem texto de parâmetros | Não |

**Prova automática:** `TestFluxoPontaAPonta` (memória e PostgreSQL) cadastra um cliente com nome e e-mail sintéticos, envia o e-mail também numa query string e falha se qualquer um deles aparecer no log.

**Observação:** o `clienteId` (UUID) aparece nos logs. É um identificador pseudônimo, permitido por C-09 ("somente IDs"); sozinho, ele não identifica a pessoa sem acesso ao banco.

## 6. Requisitos futuros (pós-MVP)

1. Rotas de acesso, correção, portabilidade e eliminação (L-19), e uma política de retenção com expurgo após revogação (L-20, D-13).
2. Filtrar o uso dos dados pela finalidade consentida (L-04) e manter o histórico de versões do termo (L-06).
3. Autenticação por usuário (JWT/OIDC) com perfis Cliente, Administrador e Analista (L-12).
4. Certificado emitido por uma autoridade, cifra do volume do banco e TLS interno (L-10, L-16).
5. Prazo de retenção dos logs definido junto com a política de dados.